

Clase 299 — IA ofensiva y deepfakes

Parte: **15 — Seguridad de IA y machine learning** · Fuente: *MITRE ATLAS* y NIST AI 600-1 (perfil de IA generativa) 🕒 Duración estimada: **100 min** · Nivel: **Avanzado**

🎯 Objetivo

Comprender cómo los atacantes aprovechan la IA generativa —phishing hiperpersonalizado, deepfakes de voz e imagen, malware asistido, automatización de reconocimiento— y, sobre todo, cómo defenderse: detección de contenido sintético, procedencia (C2PA), verificación fuera de banda y concienciación. El enfoque es **defensivo**: entender la amenaza para neutralizarla.

⚠️ **Ética:** esta clase describe capacidades ofensivas con fines de defensa. No generamos deepfakes de personas reales, ni contenido para fraude, ni malware funcional. Cualquier prueba usa material propio y consentido, en laboratorio aislado. La suplantación y el fraude son delitos.

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

- 1. **Catalogar** los usos ofensivos de la IA generativa y su impacto.
- 2. **Explicar** cómo funcionan los deepfakes de voz e imagen a alto nivel.
- 3. **Aplicar** técnicas de detección y de verificación de procedencia (C2PA/marcas de agua).
- 4. **Diseñar** controles anti-vishing/anti-fraude con verificación fuera de banda.
- 5. **Formar** a usuarios y procesos para resistir ingeniería social potenciada por IA.

📖 Temas

#	Tema	Por qué importa
1	Phishing y BEC potenciados por LLM	Correos perfectos, a escala, sin errores
2	Deepfakes de voz (vishing)	Fraude del "CEO" y suplantación telefónica
3	Deepfakes de vídeo e imagen	Desinformación y verificación de identidad
4	Malware y ofensiva asistida por IA	Aceleración, no magia; límites reales
5	Detección de contenido sintético	Clasificadores y sus limitaciones
6	Procedencia: C2PA y watermarking	Probar el origen en vez de detectar la falsificación
7	Verificación fuera de banda y procesos	La defensa organizativa que sí escala

Definiciones y características

- **Deepfake:** contenido sintético (voz, imagen, vídeo) generado o alterado con IA para parecer real. *Característica:* la calidad crece más rápido que la detección.
- **Vishing con clonación de voz:** llamada fraudulenta usando una voz clonada de un directivo conocido. *Característica:* explota confianza y urgencia; deriva en transferencias.
- **BEC (Business Email Compromise) asistido:** correos de fraude redactados por LLM, sin errores idiomáticos y personalizados con OSINT. *Característica:* elimina las señales clásicas del phishing.
- **C2PA / Content Credentials:** estándar de procedencia que firma criptográficamente el origen y las ediciones de un contenido. *Característica:* verifica autenticidad en lugar de detectar falsedad.
- **Watermarking de IA:** marca imperceptible incrustada en contenido generado para identificarlo. *Característica:* frágil ante recompresión/edición.
- **Verificación fuera de banda:** confirmar una solicitud sensible por un canal distinto y previamente acordado. *Característica:* control organizativo robusto contra suplantación.

Herramientas y preparación

- Estándar **C2PA** y verificadores de Content Credentials (para inspeccionar procedencia de imágenes propias).
- Detectores de contenido sintético como referencia (entendiendo su fiabilidad limitada).
- Material propio y consentido para pruebas (tu propia voz/imagen), nunca de terceros.
- Un procedimiento de laboratorio para simular un intento de fraude (role-play controlado con compañeros que consienten).

Laboratorio guiado (defensivo)

Todo con **material propio/consentido** y foco en detección y proceso.

1. **Analiza un correo de phishing potenciado por IA.** Toma un ejemplo (propio o de un repositorio de concienciación) y lista qué señales clásicas han desaparecido (gramática, genericidad) y qué señales quedan (dominio, urgencia, canal de pago).
2. **Inspecciona procedencia con C2PA.** Sobre una imagen con Content Credentials, verifica la firma y el historial de ediciones. Sobre una sin credenciales, discute qué NO puedes afirmar.
3. **Prueba un detector de contenido sintético** con imágenes/voz propias (generadas con consentimiento o de repositorios de investigación). Mide su fiabilidad: anota falsos positivos y negativos. Concluye que la detección no es garantía.
4. **Diseña un control anti-vishing.** Define un procedimiento: toda solicitud de transferencia o cambio de datos bancarios requiere verificación fuera de banda con un código/canal acordado, sin excepciones por urgencia.
5. **Simula un intento de fraude (role-play consentido).** Un compañero interpreta al "CEO" pidiendo una transferencia urgente; el resto aplica el procedimiento. Evalúa dónde falla el proceso, no las personas.
6. **Redacta guía de concienciación.** Convierte lo aprendido en 5 reglas prácticas para empleados frente a ingeniería social potenciada por IA.

7. **Mapea a ATLAS.** Sitúa estas técnicas ofensivas en MITRE ATLAS y en la fase de la cadena de ataque correspondiente.

 Ejercicios

- 1. Enumera 5 señales de phishing que la IA generativa ha vuelto obsoletas y 3 que siguen sirviendo.
- 2. Explica a alto nivel cómo se clona una voz y por qué basta poco audio.
- 3. Compara "detección de deepfakes" vs. "procedencia C2PA" como estrategias y sus límites.
- 4. Diseña el procedimiento fuera de banda para autorizar pagos por encima de un umbral.
- 5. Evalúa la fiabilidad de un detector de imágenes sintéticas con un pequeño conjunto propio.
- 6. Redacta un guion de simulacro de vishing ético y consentido para tu organización.

 Reto verificable

Entrega un **paquete de defensa anti-suplantación IA**: (a) análisis de un caso de BEC/deepfake, (b) un procedimiento documentado de verificación fuera de banda para acciones sensibles, y (c) una guía de concienciación de una página.

Criterio de aceptación: el procedimiento fuera de banda define umbral, canal alternativo acordado y regla de "sin excepciones por urgencia", y el caso analizado demuestra por qué la detección técnica por sí sola no habría bastado. Nada del entregable usa datos o identidades de terceros sin consentimiento.

 Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
Confiar solo en detectores de deepfake	Los detectores fallan y envejecen rápido. Prioriza procesos de verificación fuera de banda.
"El correo es perfecto, será legítimo"	La IA elimina las señales de redacción. Verifica dominio, canal y contexto, no la calidad del texto.
Autorizar pagos por urgencia	Ingeniería social clásica amplificada. La urgencia nunca anula el procedimiento.
Asumir que C2PA prueba que algo es falso	C2PA prueba procedencia cuando está presente; su ausencia no prueba falsedad.
Hacer pruebas con voces/rostros de terceros	Ilegal y poco ético. Usa solo material propio y consentido.

 Preguntas frecuentes

-  **¿La IA hace a los atacantes imparables?** No. Baja la barrera de entrada y escala los ataques, pero las defensas de proceso (verificación fuera de banda, mínimo privilegio, MFA) siguen siendo efectivas porque no dependen de detectar el engaño.
-  **¿Puedo detectar de forma fiable un deepfake?** No de forma garantizada. Los detectores tienen falsos positivos y negativos y se degradan frente a nuevos generadores. Úsalos como señal, no como veredicto.

❓ **¿Qué es más útil, detección o procedencia?** La procedencia (C2PA) es más prometedora a largo plazo: en vez de perseguir cada falsificación, verifica criptográficamente el origen del contenido auténtico. Requiere adopción del ecosistema.

❓ **¿Genera la IA malware indetectable?** Acelera tareas (variantes, ofuscación, guiones), pero no crea magia indetectable. Las defensas de endpoint y comportamiento siguen aplicando; el mayor salto es en ingeniería social.

Referencias

- MITRE ATLAS — <https://atlas.mitre.org/>
- NIST AI 600-1, Generative AI Profile — <https://www.nist.gov/itl/ai-risk-management-framework>
- C2PA (Coalition for Content Provenance and Authenticity) — <https://c2pa.org/>
- FBI IC3, alertas sobre BEC y deepfakes — <https://www.ic3.gov/>
- ENISA, Threat Landscape (secciones de IA/desinformación) — <https://www.enisa.europa.eu/>

Siguiendo clase

Clase 300 - Gobernanza y ética de la IA segura